==========

1. DESCRIPTION SIMPLE — CE QU'EST LE PITR

Le Point-in-Time Recovery (PITR), ou "récupération à un instant précis" en français, est une fonctionnalité de sauvegarde avancée pour les bases de données. Elle permet de restaurer une base de données exactement dans l'état où elle se trouvait à n'importe quel moment dans le passé, à la seconde près.

Exemple concret appliqué au projet Lidl Drive :

- Il est 14h37 un mercredi. Un bug dans le backend efface par erreur toutes les commandes en cours du magasin d'Échirolles.
- Avec le PITR, on peut restaurer la base telle qu'elle était à 14h36, soit 60 secondes avant le bug. Aucune commande perdue.
- Sans PITR, la restauration la plus récente disponible est celle de la nuit précédente. On perd une journée entière de données : commandes, créneaux réservés, statuts de préparation, etc.

En résumé : là où une sauvegarde classique te ramène à "hier soir", le PITR te ramène à "il y a une minute".

2. DESCRIPTION TECHNIQUE — FONCTIONNEMENT INTERNE

Le PITR repose sur deux mécanismes PostgreSQL combinés :

A) Les sauvegardes physiques de base (base backup) Supabase prend régulièrement un instantané complet de la base de données au niveau des fichiers disque (et non au niveau SQL). C'est une copie binaire de l'intégralité du répertoire de données PostgreSQL.

B) Les fichiers WAL — Write-Ahead Log PostgreSQL enregistre chaque transaction dans un journal de transactions appelé WAL (Write-Ahead Log) avant même de les appliquer à la base. Ces fichiers WAL constituent une trace chronologique et exhaustive de toutes les modifications apportées à la base.

Processus de restauration : 1. Supabase charge la dernière sauvegarde physique (base backup) antérieure au point de restauration souhaité. 2. Supabase télécharge ensuite l'ensemble des fichiers WAL générés entre cette sauvegarde et le point cible. 3. PostgreSQL rejoue ("replay") les transactions WAL dans l'ordre chronologique jusqu'à atteindre exactement le timestamp demandé. 4. La base est reconstruite dans l'état exact souhaité, à la seconde près.

Précision maximale : jusqu'à la seconde. Fenêtre de récupération : 7, 14 ou 28 jours selon le plan souscrit.

Note : lorsque le PITR est activé, les sauvegardes quotidiennes classiques sont désactivées. Le PITR les remplace entièrement, car il offre une granularité bien supérieure.

---

3. QUI PRODUIT CETTE SOLUTION

Éditeur du service : Supabase, Inc. Siège social : San Francisco, Californie, États-Unis Fondé en : 2020 Type : Société privée, open source (licence Apache 2.0) Site officiel : https://supabase.com Documentation PITR : https://supabase.com/docs/guides/platform/backups

Infrastructure sous-jacente : Amazon Web Services (AWS) Supabase ne possède pas ses propres datacenters. L'intégralité de son infrastructure repose sur les datacenters AWS, héritant ainsi de leur niveau de sécurité, de leur uptime garanti et de leur certification (ISO 27001, SOC 2, etc.).

Régions disponibles en Europe (pertinentes pour notre projet) : - EU West — Irlande (AWS eu-west-1, Dublin) - EU West — Royaume-Uni (AWS eu-west-2, Londres) - EU Central — Allemagne (AWS eu-central-1, Francfort) ← RECOMMANDÉE

Région recommandée pour le projet Lidl Drive : EU Central — Frankfurt (Allemagne) — AWS eu-central-1 Raisons : - Proximité géographique avec Grenoble (~900 km, latence minimale) - Données hébergées dans l'UE → conformité RGPD simplifiée - Région la plus proche parmi les options européennes - Pas de transfert de données hors Espace Économique Européen

---

4. CE QUE LE PITR PERMETTRAIT POUR NOTRE PROJET LIDL DRIVE

Notre webapp gère des données métier critiques dont la perte aurait un impact direct sur l'activité : commandes clients, statuts de préparation, créneaux de retrait réservés, stocks par magasin, comptes clients.

Scénarios couverts par le PITR :

[1] Suppression accidentelle de données Situation : un développeur exécute un DELETE sans clause WHERE en production, effaçant toutes les lignes de la table "order". Avec PITR : restauration à T-30 secondes. Perte de données : nulle. Sans PITR : restauration au backup de la nuit. Perte : une journée.

[2] Bug applicatif affectant les données Situation : une mise en production introduit un bug qui corrompt les statuts de toutes les commandes (ex. toutes passent à "ANNULEE"). Avec PITR : restauration précise au moment juste avant le déploiement. Sans PITR : impossible d'annuler sélectivement les modifications.

[3] Erreur de migration de base de données Situation : un script de migration SQL supprime des colonnes ou des tables par erreur lors d'une montée de version. Avec PITR : rollback immédiat au point précédant la migration.

[4] Attaque ou intrusion Situation : un acteur malveillant accède à la base et supprime ou modifie des données clients ou des commandes. Avec PITR : restauration à un point antérieur à l'intrusion, après identification de l'heure exacte de l'attaque via l'AuditLog.

[5] Incident de synchronisation stock/commande Situation : une désynchronisation entre les tables "stock" et "order" génère des données incohérentes (commandes acceptées sans stock). Avec PITR : retour à un état cohérent identifié.

[6] Problème de créneau (PickupSlot) Situation : suite à un bug, des créneaux sont marqués complets à tort, bloquant les clients. On veut revenir à l'état correct. Avec PITR : restauration sélective possible au point exact du bug.

---

5. INCIDENTS ÉVITÉS GRÂCE AU PITR

Sans PITR, les incidents suivants sont irréversibles ou très coûteux :

- Perte d'une journée de commandes clients en cas d'incident en journée (le backup quotidien ayant été pris la nuit précédente)
- Impossibilité de cibler un instant précis : on ne peut revenir qu'à des points fixes (la veille, deux jours avant, etc.)
- En cas d'attaque à 11h du matin, la restauration depuis le backup de minuit implique une perte de 11 heures de transactions
- Perte définitive des données de fidélité (client_history) si la table est corrompue entre deux backups quotidiens
- Impossibilité de prouver l'état exact de la base à un moment donné, ce qui complique les litiges clients ("ma commande était confirmée")

---

6. FRÉQUENCE DES SAUVEGARDES AVEC PITR

Mécanisme WAL (Write-Ahead Log) : Les fichiers WAL sont envoyés en continu vers le stockage AWS S3 dès qu'ils sont écrits par PostgreSQL. La fréquence effective est quasi continue, à chaque transaction.

Sauvegardes physiques de base (base backup) : Prises régulièrement par Supabase (fréquence interne Supabase, non configurable par l'utilisateur). Elles servent de point de départ pour la reconstruction lors d'une restauration.

Précision de restauration garantie : jusqu'à la seconde.

Comparaison avec les backups classiques (sans PITR) : Plan Free → aucune sauvegarde automatique (dumps manuels recommandés) Plan Pro → 1 backup par jour, rétention 7 jours Plan Team → 1 backup par jour, rétention 14 jours PITR 7j → continu, restauration à la seconde, fenêtre de 7 jours PITR 14j → continu, restauration à la seconde, fenêtre de 14 jours PITR 28j → continu, restauration à la seconde, fenêtre de 28 jours

---

——————— 7. EMPLACEMENT DES SERVEURS ET DONNÉES

Infrastructure principale : Fournisseur : Amazon Web Services (AWS) Région choisie : eu-central-1 — Frankfurt, Allemagne Localisation : Datacenter AWS de Francfort (plusieurs AZ disponibles) Souveraineté : Données hébergées dans l'Union Européenne

Stockage des sauvegardes PITR : Les fichiers WAL et les sauvegardes physiques sont stockés sur Amazon S3, dans la même région AWS (eu-central-1) que le projet principal. Ils ne quittent pas la zone géographique européenne.

Conformité RGPD : Le choix de Frankfurt garantit que les données personnelles des clients (table "client", "client_account", "client_history") restent dans l'EEE. Cela simplifie les obligations de déclaration et de registre RGPD (responsabilité de Léo — chargé cybersécurité).

Accès aux données de sauvegarde : Accessible uniquement via le Dashboard Supabase ou l'API Management Supabase avec un jeton d'accès authentifié. Aucun accès direct S3.

Suppression des données : Attention : si le projet Supabase est supprimé, toutes les sauvegardes PITR associées sont également supprimées définitivement. Cette action est irréversible. À ne jamais faire sans validation de l'équipe.

——————— 8. TARIFICATION PITR — INFORMATION POUR LE CHEF DE PROJET

Le PITR est un add-on payant, disponible à partir du plan Pro ($25/mois). Il nécessite également au minimum une instance "Small compute" ($15/mois).

Tarifs PITR (source : docs.supabase.com, avril 2026) :

```
Rétention 7 jours  → $0.137/heure  → ~$100/mois
Rétention 14 jours → $0.274/heure  → ~$200/mois
Rétention 28 jours → $0.550/heure  → ~$400/mois
```

Coût total estimé pour notre projet (PITR 7 jours) : Plan Pro : $25/mois Compute Small : $15/mois (requis pour le PITR) PITR 7 jours : $100/mois Crédit compute : -$10/mois ———————————————————— TOTAL ESTIMÉ : ~$130/mois (~120€/mois)

Note pour le projet académique : Dans le cadre de notre projet B3, le PITR n'est PAS activé en production. Notre stratégie de backup repose sur des dumps manuels hebdomadaires via la CLI Supabase (gratuit), stockés sur le Google Drive du groupe. Ce document sert à présenter ce que le PITR permettrait dans un contexte de production réelle pour Lidl.

——————— 9. PROCÉDURE DE RESTAURATION PITR — POUR LE RESPONSABLE MAINTENANCE

Via le Dashboard Supabase (méthode graphique) : 1. Se connecter à https://supabase.com/dashboard 2. Sélectionner le projet "lidl-drive" 3. Aller dans Database > Backups > Point in Time 4. Cliquer sur "Start a restore" 5. Sélectionner la date et l'heure exacte de restauration souhaitée 6. Vérifier que le point sélectionné est dans la fenêtre de rétention 7. Confirmer — le projet devient inaccessible pendant la restauration 8. Durée de restauration : variable selon la taille de la base (de quelques minutes à plusieurs dizaines de minutes) 9. Une notification s'affiche dans le dashboard à la fin du processus

Via l'API Management Supabase (méthode programmatique) :

```
curl -X POST
"https://api.supabase.com/v1/projects/nbjzohcoepdcocgcmwus/database/backups/restore-pitr"
-H "Authorization: Bearer VOTRE_TOKEN_SUPABASE"
-H "Content-Type: application/json"
-d '{"recovery_time_target_unix": "TIMESTAMP_UNIX_CIBLE"}'
```

Points d'attention avant toute restauration : - Le projet est INACCESSIBLE pendant toute la durée de la restauration - Prévenir l'équipe et les utilisateurs avant de lancer la procédure - Identifier précisément l'heure cible AVANT de lancer la restauration (consulter l'AuditLog pour retrouver le moment exact de l'incident) - Les subscriptions et replication slots doivent être supprimés avant et recréés après (Supabase gère automatiquement le slot Realtime) - Une restauration écrase l'état actuel de la base : irréversible

---

——————— 10. INFORMATIONS POUR LE CHARGÉ CYBERSÉCURITÉ (LÉO)

Le PITR est un outil de résilience mais aussi de conformité cybersécurité.

Apport pour la posture de sécurité :

[Traçabilité] La table AuditLog de notre schéma permet d'identifier l'heure exacte d'un incident (connexion suspecte, modification frauduleuse de statut, suppression non autorisée). Cette heure sert de point de référence pour la restauration PITR.

[Réponse à incident] Le PITR s'inscrit dans le plan de réponse aux incidents de sécurité : en cas d'intrusion avérée avec modification des données, la restauration permet de revenir à un état sain.

[Preuve et auditabilité] Les fichiers WAL constituent eux-mêmes une preuve de l'historique des transactions, utile en cas de litige ou d'enquête post-incident.

[RGPD — Droit à l'effacement] Point d'attention : si un client demande l'effacement de ses données (Article 17 RGPD), il faut savoir que les données supprimées en base principale subsistent dans les fichiers WAL et les sauvegardes PITR pendant la durée de rétention souscrite. Cela doit être documenté dans le registre RGPD et la politique de confidentialité. Supabase ne propose pas de mécanisme d'effacement sélectif dans les WAL — l'effacement complet des backups associés au projet est la seule option, ce qui est disproportionné. Recommandation : gérer le droit à l'effacement par anonymisation (pseudonymisation des champs PII) plutôt que suppression physique.

[Accès aux sauvegardes] L'accès aux sauvegardes PITR doit être restreint aux administrateurs uniquement. Vérifier que les tokens d'accès API Supabase ne sont pas exposés dans le code source (variables d'env).

Certifications de l'infrastructure AWS sous-jacente : - ISO/IEC 27001 (sécurité de l'information) - SOC 2 Type II - GDPR/RGPD (hébergement dans l'UE, Frankfurt) - PCI DSS Level 1 (paiements — non applicable à notre MVP)

——————— 11. SYNTHÈSE — TABLEAU DE BORD DÉCISIONNEL

Critère | Sans PITR (backup quotidien) | Avec PITR 7j

——— Granularité | 1 point/jour | 1 point/seconde Perte max de données | Jusqu'à 24h | Quelques secondes Restauration depuis | Minuit (backup fixe) | N'importe quel instant Coût mensuel (Pro) | $25 | ~$130 Disponible sur Free | Non | Non Requiert compute minimum | Non | Small ($15/mois) Couverture scénario bugfix| Partielle | Totale Couverture attaque | Partielle | Quasi-totale Conformité RGPD sauvegardes| Limitée | À documenter (WAL) Recommandé pour production| Non | Oui Recommandé pour notre MVP | Non (trop cher) | À préciser en soutenance

Décision pour notre projet : Le PITR n'est pas activé dans notre MVP par contrainte budgétaire. Notre stratégie de backup actuelle : dumps CLI hebdomadaires + Google Drive. En production réelle pour Lidl, le PITR 7 jours ($130/mois) serait le minimum acceptable pour garantir la continuité de service.

——————— SOURCES ET RÉFÉRENCES

---

[1] Documentation officielle Supabase — Database Backups https://supabase.com/docs/guides/platform/backups

[2] Documentation officielle Supabase — Manage PITR Usage https://supabase.com/docs/guides/platform/manage-your-usage/point-in-time-recovery

[3] Supabase — Regions disponibles https://supabase.com/docs/guides/platform/regions

[4] AWS — Région eu-central-1 Frankfurt https://aws.amazon.com/about-aws/global-infrastructure/regions_az/

[5] Règlement UE 2016/679 (RGPD) — Article 17 (droit à l'effacement) https://gdpr-info.eu/art-17-gdpr/

———————— 12. POLITIQUE DE RÉTENTION (SAUVEGARDES ET RGPD) ————————

Cette section détaille la stratégie de conservation des données, tant sur le plan technique (sauvegardes PITR) que sur le plan légal (RGPD/CNIL).

A) RÉTENTION TECHNIQUE PITR : QUELLE FENÊTRE CHOISIR ?

```
Le service propose trois fenêtres de récupération possibles : 7, 14 ou 28 jours[cite: 16].
Le choix dépend d'un équilibre entre le coût financier et le besoin de sécurité.

- PITR 7 jours (~100$/mois)[cite: 51]: Option recommandée.
  Dans un contexte de e-commerce comme Lidl Drive, le flux
  d'activité est quotidien (commandes, retraits). Une erreur de manipulation
  ou un bug critique est généralement détecté très rapidement (en quelques
  heures). Une fenêtre de 7 jours est donc largement suffisante pour un
  retour en arrière réactif. C'est le minimum acceptable recommandé pour
  garantir la continuité de service de notre MVP en production[cite: 89].

- PITR 14 jours (~200$/mois)[cite: 51]: Option de confort.
  Pourquoi ? Pertinent si l'équipe technique craint de ne pas détecter
  immédiatement une corruption "silencieuse" (par exemple, un script qui
  altèrerait très discrètement les historiques de fidélité au fil des jours).

- PITR 28 jours (~400$/mois)[cite: 51]:
  Le coût est élevé mais et  est  utile pour de la grande distribution
  où les données métiers d'il y a un mois (paniers en cours, créneaux) qui ont une pertinen
  pour une restauration à l'identique ou des comparatifs.
```

B) RÉTENTION DES DONNÉES MÉTIER (CONFORMITÉ RGPD ET CNIL)

```
Au-delà des sauvegardes, notre base de données principale doit respecter
des durées de conservation légales. Voici la politique applicable à notre
modèle de données (schéma PostgreSQL) :

[1] Données clients (Comptes, adresses, profils)
    Durée : 3 ans maximum à compter de la dernière activité (connexion ou commande).
    Action : Purge ou anonymisation stricte (pseudonymisation) de la table
    "client" une fois ce délai dépassé, conformément aux recommandations CNIL.

[2] Commandes et facturation (Historique des achats)
    Durée : 10 ans.
    Action : Conservation obligatoire à des fins de preuve comptable
    (Article L123-22 du Code de commerce). Même si un client demande
    la suppression de son compte, ses factures passées doivent être gardées.

[3] Données bancaires
    Durée : Aucune conservation sur notre infrastructure.
    Action : La gestion est déléguée à un prestataire de paiement tiers.
    Notre base ne stocke que des tokens de transaction et des statuts
    (payé, échoué), jamais de numéros de carte de crédit.

[4] Logs de sécurité (AuditLog)
    Durée : 6 mois à 1 an maximum.
    Action : Les traces de connexion (adresses IP, timestamps) utiles pour
    l'identification d'incidents doivent subir une rotation régulière.
```

C) CROISEMENT RGPD ET SAUVEGARDES (LE DROIT À L'OUBLI)

```
Il existe un conflit technique naturel entre le droit à l'effacement et le PITR.
Si un client exerce son droit à l'effacement (Article 17 du RGPD), ses
données sont immédiatement supprimées de la base principale.
Cependant, ces informations subsisteront dans les sauvegardes physiques et les
fichiers WAL jusqu'à l'expiration de la période de rétention choisie [cite: 63]
(ex: pendant les 7 jours suivant la suppression).

Ce comportement est toléré par la réglementation à trois conditions :
1. La durée de rétention des backups est documentée et raisonnable (7 jours).
2. Ces backups sont sécurisés et ne servent qu'à la reprise sur incident[cite: 67].
3. Si une restauration PITR doit être effectuée depuis un point dans le passé,
   toutes les demandes de suppression de clients reçues entre ce point
   du passé et aujourd'hui devront être ré-appliquées manuellement par l'équipe.
```

==========